ha-coap-server Code Review

Proposed changes to the `hacoap` firmware, board definition and firmware-update tooling

Repository	`ha-coap-server`, reviewed at `main` commit `04789f2`
Target	ha-coap-node Rev 2.0 (ACN52840 / nRF52840), board `hacoap`, Thread MTD sleepy end device
SDK	nRF Connect SDK v2.4 (sdk-nrf fork `v2.4-branch`, Zephyr `v3.3.99-ncs1-branch`, OpenThread `d5a6630`)
Review date	2026-10-24
Status	**Proposed; no code changes applied yet.** Items 1–14 are ready to implement. Items A–F need a decision first.
Verification	SDK and OpenThread behavior cited below was checked against the NCS 2.4 sources. The firmware was **not compiled**, because there is no NCS install on the review machine, so every change needs a build and a hardware check.
Prepared by	Claude (AI-assisted review, prepared with Claude Code). Companion document: `docs/hardware/ha-coap-node-rev2.0-schematic-review.pdf`.

Summary

The firmware is compact and readable, and the CoAP resource layer is cleanly separated from the application callbacks. The review found a few defects with real effects. A UART pin assignment that **disables the battery charger**. CoAP responses that **carry garbage header bytes** whenever the client uses a token. A debug build preset that **exits `main()` before OpenThread starts**. And a startup sequence that abandons networking, and with it over-the-air recovery, if any single sensor fails to initialize. The power-related items are the firmware side of the schematic review. The web-based updater has security exposures on the LAN and does not currently drive its update script.

#	Priority	Area	Finding
1	HIGH	Board DTS	UART0 RTS is on P0.05 (charger PROG) and is driven high, which disables charging.
2	HIGH	CoAP	The token is set twice, so responses carry uninitialized bytes parsed as options.
3	MEDIUM	CoAP	The `/data` payload length is `sizeof(pointer)`.
4	MEDIUM	Startup	`LOG_ERR("%s")` has no argument on the sensor-not-ready paths.
5	HIGH	Startup	The USB logging preset makes `usb_enable()` return `-EALREADY`, and `main()` then exits.
6	MEDIUM	Board DTS	`nordic,invert` keeps the buzzer MOSFET on for about 2.5 s at every boot.
7	MEDIUM	ADC	Unsigned sample buffer, an uninitialized value on read failure, and the code copied three times.
8	LOW	Code quality	Header guard typo, mismatched callback types, a declaration after a `case` label, and buffer over-reads.
9	HIGH	Robustness	Any sensor failure stops startup before OpenThread, so the device becomes unreachable.
10	LOW	Robustness	Actuators are driven as DK "LEDs" by array position, which is fragile.
11	MEDIUM	Power	The time-of-flight shutdown pin is held low (about 300 µA), and the VL53L0X driver can never initialize.

#	Priority	Area	Finding
12	MEDIUM	Build config	The battery (MTD) build has debug optimizations on. The NFC-pin setting is in the wrong file.
13	HIGH	Tooling	The web updater exposes the Werkzeug debugger, allows arbitrary file reads, and is open to shell injection.
14	LOW	Repo	Committed `__pycache__` and log file, a wrong OpenOCD subfamily, and a dead include directory.
A–F	DECIDE	Various	DC/DC enable, `/info` device ID, web updater mode, signing and partitions, sampling model, watchdog.

1. Bugs to fix first

1 UART0 flow-control pins disable the battery charger HIGH

Where. `boards/arm/hacoap/hacoap-pinctrl.dtsi:13` and `:25`. RTS is on P0.05 and CTS on P0.07.

Evidence. On this board P0.05 is net I_BATT, the STC4054 PROG pin. Zephyr's `pinctrl_nrf.c` configures `NRF_FUN_UART_RTS` as an output with an initial level of 1, and `uart0` is enabled in the base DTS. Per the STC4054 datasheet, PROG above 1.21 V puts the charger into shutdown, and above 2.4 V about 35 µA flows into the pin. P0.07 is not wired on the ACN52840 module.

Change. Remove the RTS and CTS `psels` from `uart0_default` and `uart0_sleep`. TX on P0.06 and RX on P0.08 stay on J4.

Test. On USB power with a partly discharged battery, check that the orange CHRG LED is on and PROG reads about 1.0 V during constant-current charge.

2 CoAP responses carry garbage bytes when the request has a token HIGH

Where. `src/ot_coap_utils.c:494, 627, 702, 767, 837`: the `pumpdc` and `pump` GET responses, `data`, `info` and `ping`.

Evidence. In OpenThread, `otCoapMessageInitResponse()` already copies the request token (`SetTokenFromMessage`). `Message::SetToken()` adds the token length to `mHeaderLength` every time it is called. Calling `otCoapMessageSetToken()` afterwards therefore grows the message by a second token length. `Finish()` only writes the header up to the option start, so N bytes of uninitialized buffer sit between the token and the payload marker, and the client parses them as options. Requests without a token, such as `coap-client`'s default, do not show the problem.

Change. Delete the five redundant `otCoapMessageSetToken()` blocks. Payload formats are unchanged.

Test. `coap-client -m get -T cafe coap://[addr]/data -v 9` should show no unexpected options. Check that the HA integration still parses every resource.

3 `/data` payload length is the size of a pointer MEDIUM

`src/ot_coap_utils.c:717` uses `sizeof(data_buf)` where `data_buf` is an `int8_t *`. It works only because both are 4 bytes on Cortex-M. **Change:** define the payload length once (4 bytes: soil %, state of charge, air humidity, temperature) and use it on both sides. The bytes on the wire do not change.

4 Error logs with a missing format argument MEDIUM

`src/coap_server.c:759` and `:797`: `LOG_ERR("...Device \"%s\" is not ready...")` has no argument, so the logger reads an arbitrary pointer exactly when the HDC1080 or the fuel gauge is missing. **Change:** pass `dev->name`.

5 The USB logging preset stops in `main()` before anything starts HIGH

Evidence. `overlay-usb.conf`, used by the `build_ftd_usb_logging` preset, sets `CONFIG_USB_DEVICE_INITIALIZE_AT_BOOT=y`, so Zephyr calls `usb_enable()` during boot. The second call in `main()` (`src/coap_server.c:584`) returns `-EALREADY` (`usb_device.c`). `main()` then exits through `goto end`, and LEDs, sensors, CoAP and OpenThread never start. The error path also calls `dk_set_led_on()` before `dk_leds_init()`.

Change. Treat `-EALREADY` as success, and initialize the LEDs first so that later error indications work.

Test. Build both presets. The logging build should boot, log over CDC ACM and join the network.

6 Buzzer MOSFET on during boot MEDIUM

`hacoap-pinctrl.dtsi:56` sets `nordic,invert` on PWM_OUT0 (P0.12, the Q3 gate). `pinctrl_nrf.c` writes the pin high, and `pwm_nrfx.c` treats that as an inverted, idle-high channel until the first `pwm_set_dt()` call, which uses normal polarity. That leaves Q3 on from driver init until the boot jingle, about 2.5 s including the 2150 ms delay at the start of `main()`. During that time R20 draws VCC/1 kΩ ≈ 4–5 mA, and DC sits across the piezo. **Change:** remove `nordic,invert`. **Test:** P0.12 stays low from reset until the jingle.

7 ADC sampling: signedness, uninitialized value, duplicated code MEDIUM

- The sample buffer is `uint16_t buf` (`include/coap_server.h:169`). The SAADC in single-ended mode can return small negative codes, which wrap to about 65 000 and clamp to "dry" (0 %).
- `val_mv` is used uninitialized when `adc_read()` fails (`src/coap_server.c:86–117` and `:898–926`).
- The read-and-convert logic is copied in `on_data_request()`, `main()` and the ADC timer handler.

Change: one `read_soil_moisture()` helper with an `int16_t` buffer that returns an error code. Callers report 0 on failure. Calibration constants are unchanged.

8 Smaller correctness items LOW

- The header guard defines `__OT_COAP_SEVER_H__` but tests `__OT_COAP_SERVER_H__` (`include/coap_server.h:11–12`). The header also defines objects, so it can only ever be included once. Move those definitions into `coap_server.c`.
- `on_pumpdc_request(int)` (`src/coap_server.c:30`) is passed as a `uint8_t (*)(uint8_t)` callback. `on_data_request()` returns `int8_t *` to a `uint8_t` buffer.
- A declaration directly follows a `case` label in `on_thread_state_changed()`. Wrap the case body in braces.
- The three SRP-name `memcpy` calls copy `sizeof(src) + 1` bytes (one past the source) and ignore the buffer size OpenThread returns (`src/coap_server.c:314–321`). Use a bounded copy.
- The `SRP_CLIENT_MANUAL` path assigns a string to a `uint32_t`. It is dead code today, but would not compile if selected.
- Duplicate `#include`, unused globals (IMU and TOF leftovers), and `%d` used for `size_t`.

2. Robustness

9 A failed sensor takes the whole device offline HIGH

If the HDC1080 (`src/coap_server.c:757`), the fuel gauge (`:795`) or the ADC (`:876`) isn't ready, `main()` takes `goto end` before CoAP and OpenThread start. A failed button configuration returns early as well. The device then never joins the network, cannot be reached, and cannot be updated over UDP.

Change: log the failure, mark that sensor unavailable, and continue. `/data` reports 0 for unavailable values, which is what the fuel-gauge error path already does, so the HA integration needs no change. **Test:** boot with a sensor missing (or with its node disabled in the DTS). The device should still join the network and answer CoAP.

10 Actuators are driven through the DK LED library by position LOW

The pump, time-of-flight shutdown, sensor enable and VS_SEL are children of the DTS `leds` node and are addressed as DK LED indices 4–7 (`include/coap_server.h`). Removing or reordering a node silently shifts every later index. **Change:** drive these pins with `gpio_dt_spec` from the existing aliases (`pump1`, `sensor-en`, `sensor-pwr`), configured as `GPIO_OUTPUT_INACTIVE`. Keep the DK library only for the real LEDs. Item 11 depends on this.

3. Power (firmware side of the schematic review)

11 Time-of-flight shutdown pin held low, and a VL53L0X driver that never initializes MEDIUM

`dk_leds_init()` configures every `leds` child as an output and turns it off. That drives P0.09 (XSHUT) low against R30 (10 kΩ to the 3.0 V rail), about 300 µA continuously. The DTS also sets `GPIO_PULL_UP` on that output. Separately, the VL53L0X node is at `reg = <0x30>`, and without `CONFIG_VL53L0X_RECONFIGURE_ADDRESS` the driver returns `-ENOTSUP` for any address other than 0x29, so the device is never ready.

Change: remove `tof_en` from `leds` and leave P0.09 unconfigured, so R30 holds the sensor in standby at a few µA. Set the VL53L0X node to `status = "disabled"` and `CONFIG_VL53L0X=n` while the feature is unused. To re-enable it later, use `reg = <0x29>` plus `xshut-gpios`. **Test:** sleep current should drop by about 0.3 mA (measure with a PPK2 or similar).

12 Debug settings in the battery build; NFC-pin setting in the wrong file MEDIUM

`overlay-mtd.conf` enables `CONFIG_DEBUG_OPTIMIZATIONS` (`-Og`) and `CONFIG_DEBUG_THREAD_INFO`, so the low-power production build is a debug build. Move both into `overlay-debug.conf`. `CONFIG_NFCT_PINS_AS_GPIOS` describes the hardware, since P0.09 and P0.10 are wired as GPIOs, so move it into `hacoap_defconfig` where every build gets it.

4. Tooling and repository

13 Web updater security HIGH

- `firmware-updater/app.py:165` runs `socketio.run(app, host='0.0.0.0', debug=True)`, which exposes the Werkzeug debug server to the whole LAN.
- `/api/logs?log_file=` opens any path the client supplies (`app.py:106`).
- The client-supplied build directory and device addresses are written unescaped into a generated shell script (`update_manager.py`).
- The Flask secret key is hard-coded.

Change: bind to 127.0.0.1 by default with debug off (both configurable). Validate addresses with Python's `ipaddress` module and the build directory against the repo. Pass parameters through the environment or argv instead of generating a script. Only serve logs from the log directory, by basename.

14 Repository hygiene LOW

- Remove the committed `firmware-updater/__pycache__/` and `web_updater.log`, and add both to `.gitignore`.
- `board.cmake:6` sets `OPENOCD_NRF5_SUBFAMILY "nrf51"`; it should be `nrf52`.
- `CMakeLists.txt` adds a nonexistent `interface` include directory.
- The board doc references `hacoap.jpg`, but the file is `hacoap.png`.
- The emoji in `scripts/mcumgr-dfu.sh` messages were mangled into control characters, which makes git treat the file as binary.

5. Decisions needed before implementation

#	Question	Trade-off and recommendation
A	**Enable the nRF52840 DC/DC regulator?** Add a board `Kconfig` with `BOARD_ENABLE_DCDC` (default y), following the nRF52840 DK pattern.	Roughly halves radio current. The ACN52840 datasheet states the DC/DC components are on the module, but if that's wrong the board won't boot until reflashed over SWD. **Recommend:** a separate commit, tested on one board first.
B	**Fix the `/info` device ID?** It is truncated to 7 hex characters (`src/coap_server.c:516`), while the SRP hostname uses all 8.	Fixing it changes the value `/info` reports. **Check first** whether the HA integration uses it as the entity's unique ID.
C	**Make the web updater work?** `mcumgr-update-all.sh` resets `DEVICE_ADDRESSES` and `BUILD_DIR`, ignores `NON_INTERACTIVE` and `UPDATE_MODE`, and prompts on stdin. The web app's log parsing also expects a log file that commit `e249ceb` removed.	Needs a non-interactive mode in the script, a moderate change. Do it now, or leave the web UI until later.

#	Question	Trade-off and recommendation
D	**Firmware signing and partition layout.** No MCUboot signing key is configured, so images are signed with MCUboot's public default key. With `overlay-udp.conf`, mcumgr upload and reset are unauthenticated and reachable from the LAN through the border router. There is also no `pm_static.yml`.	A new key means reflashing MCUboot over SWD on every board. `pm_static.yml` should be generated from a build on the development machine (`build/partitions.yml`) so that OTA images stay compatible. **Recommend:** do both before the fleet grows.
E	**Sensor reads inside the CoAP handler.** `on_data_request()` sleeps 200 ms and does I2C inside the OpenThread callback.	Sampling on a timer with cached values gives instant responses, but powers the sensor on a schedule rather than per request. **Recommend:** keep as is for now.
F	**Add a hardware watchdog?** None is used today. The `watchdog0` alias exists.	Recovers a hung stack or I2C bus in the field. Must be tested for reboot loops. **Recommend:** yes, as its own commit.

6. Compatibility and integration notes

- **Not changing:** CoAP resource names and payload formats (single ASCII character for PUTs, binary responses), the SRP hostname format `ha-coap-<id>`, service `_ot._udp`, CoAP port 5683 and mcumgr UDP port 1337. The HA integration and update scripts depend on these.
- **Negative temperatures:** `/data` byte 3 is the temperature cast to a byte, so −5 °C arrives as 251. The integration must read it as a signed `int8`.
- **SRP port:** the service registers port 49154 while CoAP listens on 5683. This is harmless if the integration ignores the advertised port.
- **Checked, no change needed:** the LSM6DSL driver leaves the IMU powered down at boot (ODR 0). The `ping` response's empty payload marker is stripped by OpenThread's `Finish()`, so the message is well-formed.

7. Implementation plan and verification

Commit	Content	Verify
1	Board definition: items 1, 6, 11 (DTS), 12 (defconfig)	Both presets build. Charging works on USB. P0.12 stays low at boot.
2	CoAP responses: items 2, 3	A token GET to every resource is clean. HA integration still works.
3	Application: items 4, 5, 7, 8, 9, 10, 11 (code)	Normal boot: jingle, join, SRP registration, pump, ping. Boot with a sensor missing still joins.
4	Build configuration: item 12 (overlays)	The MTD build no longer uses `-Og`. Image size drops.
5	Web updater security: item 13	The server binds to localhost. Bad addresses and paths are rejected.
6	Repository hygiene: item 14	`git status` is clean after a run.
opt.	Per decisions A–F	DC/DC on one board first. Watchdog soak test.

> **Before and after:** measure the average sleep current of a battery (MTD) build with a power profiler before commit 1 and after commit 4. Expect at least 0.3 mA less from item 11 alone. The board's always-on LED (schematic review item P1) masks much of this unless it is removed for the measurement.

References

1. OpenThread (sdk-openthread `d5a6630`): `src/core/api/coap_api.cpp` (`otCoapMessageInitResponse`), `src/core/coap/coap_message.cpp` (`SetToken`, `Finish`). https://github.com/nrfconnect/sdk-openthread/tree/d5a6630a839477ffb68686f0315f860cc5bc1238
2. Zephyr (sdk-zephyr `v3.3.99-ncs1-branch`): `subsys/usb/device/usb_device.c`, `drivers/pinctrl/pinctrl_nrf.c`, `drivers/pwm/pwm_nrfx.c`, `drivers/sensor/vl53l0x/vl53l0x.c`, `drivers/sensor/lsm6dsl/`, `boards/arm/nrf52840dk_nrf52840/Kconfig`. https://github.com/nrfconnect/sdk-zephyr/tree/v3.3.99-ncs1-branch
3. nRF Connect SDK (`v2.4-branch`): `lib/dk_buttons_and_leds/dk_buttons_and_leds.c`. https://github.com/nrfconnect/sdk-nrf/tree/v2.4-branch
4. ST STC4054 datasheet: PROG shutdown threshold and current. https://www.st.com/en/power-management/stc4054.html
5. aconno ACN52840 module datasheet v1.2: pinout and integrated DC/DC. https://mm.digikey.com/Volume0/opasdata/d220001/medias/docus/4325/ACN52840.pdf
6. RFC 7252, The Constrained Application Protocol (CoAP), section 3 (message format). https://www.rfc-editor.org/rfc/rfc7252